COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.7 · Scripting & Automation

Mestre CyberSec · **Aula 4.7 — Scripting & Automation** (8:20) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Automation: patching, log collection, provisionamento, resposta a alerta. Python/Bash/PowerShell. Cuidado: o script também é surface — credenciais VAULT, code review, escopo, SCA de biblioteca.

💡 Highlights que a prova CompTIA cobra

- Automation reduz erro humano — o principal source de breach
- Cuidado: script com credencial no código = risco

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'eliminates human error from repetitive tasks'=automation

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.7 — Scripting & Automation)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Automação (N/A)

Uso de scripts ou ferramentas para executar tarefas repetitivas de TI, como aplicação de patches, coleta de logs, provisionamento e resposta a alertas, com mínima intervenção humana.

⚠ ***Armadilha CompTIA:*** *CompTIA associa automação à redução ou eliminação do erro humano em tarefas repetitivas; não significa eliminar todos os riscos.*

• Scripting / Criação de scripts (N/A)

Escrita de pequenos programas ou scripts para automatizar tarefas administrativas e de segurança; scripts tornam-se parte da superfície de ataque se não gerenciados.

⚠ ***Armadilha CompTIA:*** *Script não é inerentemente inseguro, mas deve ter code review, escopo mínimo e credenciais protegidas.*

• Python (N/A)

Linguagem de script de propósito geral comumente usada para automação, ferramentas e tarefas de segurança no Security+.

⚠ ***Armadilha CompTIA:*** *Reconheça Python como linguagem de automação; a prova pode citar scripts Python para tarefas repetitivas.*

• Bash (N/A)

Shell e linguagem de script Unix/Linux usada para automatizar tarefas de linha de comando e administração de sistemas.

⚠ ***Armadilha CompTIA:*** *Bash é associado a automação em Linux/Unix; PowerShell é para Windows. Não confunda.*

• PowerShell (N/A)

Shell de linha de comando e linguagem de script da Microsoft para automatizar tarefas administrativas no Windows e na nuvem.

⚠ ***Armadilha CompTIA:*** *PowerShell = automação Windows/Microsoft; Bash = Linux/Unix. A prova pode testar essa distinção.*

• Cofre de Credenciais (N/A)

Armazenamento seguro para credenciais, chaves de API e segredos usados por scripts, evitando senhas embutidas no código.

⚠️ ***Armadilha CompTIA:*** *Credencial hard-coded em script é risco grave; use vault ou secrets management para armazenar e auditar segredos.*

• Revisão de Código (N/A)

Inspeção manual ou automatizada de scripts ou código para identificar falhas de segurança, erros de lógica e violações de política antes da implantação.

⚠️ ***Armadilha CompTIA:*** *Code review reduz risco de scripts inseguros; é um controle de desenvolvimento seguro, não apenas qualidade.*

• Análise de Composição de Software (SCA)

Análise automatizada de bibliotecas e dependências de terceiros para identificar vulnerabilidades e problemas de licença em software ou scripts.

⚠️ ***Armadilha CompTIA:*** *SCA foca em dependências ou bibliotecas vulneráveis; não confundir com SAST, que analisa código próprio, ou DAST, que testa a aplicação em execução.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma equipe de segurança usa um script Python para automatizar a aplicação de patches em servidores Linux. O script autentica em cada servidor usando uma chave SSH armazenada em um arquivo de configuração em texto claro no host de automação. Um auditor sinaliza essa prática. Qual mudança melhor corrige a constatação preservando a automação?

A) Armazenar a chave SSH em um cofre de segredos e recuperá-la em tempo de execução usando um token de curta duração.

B) Criptografar o arquivo de configuração com uma senha estática embutida no script.

C) Restringir as permissões do arquivo de configuração apenas à conta de serviço de automação.

D) Converter o script para PowerShell e executá-lo a partir de um jump host Windows.

QUESTÃO 2 · CENÁRIO DE EXAME

Um script PowerShell desabilita automaticamente contas de usuário quando o SIEM detecta um ataque de força bruta. O script é executado com uma conta de serviço administrador de domínio. Uma revisão de segurança afirma que isso viola o princípio do menor privilégio. Qual ação deve ser tomada?

A) Reescrever o script em Python para reduzir o risco de abuso do PowerShell.

B) Criar uma conta de serviço dedicada com permissões apenas para desabilitar contas nas unidades organizacionais alvo.

C) Exigir que o script solicite credenciais de administrador de domínio a cada execução.

D) Mover o script para uma tarefa agendada em um controlador de domínio.

QUESTÃO 3 · CENÁRIO DE EXAME

Um script Bash de coleta de logs envia logs de aplicação para um SIEM central. O script também copia todas as variáveis de ambiente para um arquivo de depuração armazenado em um servidor compartilhado. Qual controle de segurança deve ser aplicado primeiro?

A) Habilitar monitoramento de integridade de arquivos no servidor compartilhado.

B) Implementar validação de entrada no SIEM.

C) Sanitizar ou excluir valores sensíveis antes de gravar dados de depuração.

D) Compactar e criptografar o arquivo de depuração com uma senha compartilhada.

QUESTÃO 4 · CENÁRIO DE EXAME

Um desenvolvedor cria uma ferramenta de automação em Python para provisionamento em nuvem. Ela depende de várias bibliotecas de código aberto listadas em requirements.txt. Antes da implantação, a segurança quer identificar vulnerabilidades conhecidas nessas bibliotecas. Qual ação deve ser tomada?

A) Executar análise estática apenas no código Python de primeira parte.

B) Aplicar política de execução do PowerShell no servidor de build.

C) Usar um firewall de aplicação web na frente da API de automação.

D) Executar uma varredura de análise de composição de software (SCA) nas dependências.

QUESTÃO 5 · CENÁRIO DE EXAME

Um script de automação provisiona novas VMs em nuvem. Para economizar tempo, ele usa uma função de administrador de nuvem com acesso total à assinatura. Qual princípio deve ser aplicado para reduzir o risco?

A) Separação de funções, fazendo dois administradores executarem o script.

B) Menor privilégio, limitando a função apenas às ações de provisionamento e recursos necessários.

C) Rotação de funções entre engenheiros de nuvem.

D) Férias obrigatórias para o proprietário da conta de automação.

QUESTÃO 6 · CENÁRIO DE EXAME

Um script Bash de produção foi editado diretamente em um servidor por um administrador para corrigir um problema de análise de logs. Nenhum pull request ou teste foi realizado. O que deve ser implementado para evitar esse risco?

A) Armazenar scripts em um sistema de controle de versão com revisão por pares obrigatória antes da implantação.

B) Desabilitar Bash em todos os servidores de produção.

C) Exigir que scripts sejam executados apenas durante o horário comercial.

D) Habilitar log detalhado para todos os comandos shell.

QUESTÃO 7 · CENÁRIO DE EXAME

Um SIEM dispara um script Python automatizado que analisa campos brutos de alerta e bloqueia endereços IP. Um atacante cria uma entrada de log contendo metacaracteres de shell. Qual fraqueza deve ser corrigida?

A) Retenção insuficiente de logs.

B) Ausência de criptografia de disco completa.

C) Falta de validação de entrada antes de passar dados de alerta para comandos do sistema.

D) Criptografia Wi-Fi fraca.

QUESTÃO 8 · CENÁRIO DE EXAME

Uma empresa automatiza a implantação de patches usando um script PowerShell. O script baixa atualizações de um repositório interno e as instala. Qual controle melhor garante que os patches são legítimos e não foram adulterados?

A) Verificar assinaturas digitais ou hashes criptográficos dos pacotes antes da instalação.

B) Agendar a aplicação de patches apenas em janelas de manutenção.

C) Registrar todos os eventos de instalação de patches em um servidor syslog.

D) Executar o script com uma conta de serviço em vez de uma conta de usuário.

QUESTÃO 9 · CENÁRIO DE EXAME

Uma conta de automação executa um script Bash agendado para coletar logs de muitos servidores. A chave SSH da conta é de longa duração e compartilhada por três administradores. A segurança quer melhorar o gerenciamento de credenciais. O que deve ser feito?

A) Aumentar o tamanho da chave SSH de 2048 para 4096 bits.

B) Armazenar a chave em um arquivo ZIP protegido por senha.

C) Renomear a conta de automação para ocultar sua finalidade.

D) Substituir a chave compartilhada por certificados de curta duração emitidos por um provedor de identidade.

QUESTÃO 10 · CENÁRIO DE EXAME

Um engenheiro de segurança escreve um script PowerShell para responder a alertas isolando endpoints. O script pode modificar qualquer endpoint no domínio corporativo. Qual ação melhor se alinha com práticas seguras de automação?

A) Ofuscar o script para impedir que atacantes o leiam.

B) Limitar as permissões do script a um grupo definido de endpoints e exigir aprovação para ações de alto impacto.

C) Executar o script apenas da estação de trabalho do engenheiro de segurança.

D) Configurar o script para ignorar a política de execução por confiabilidade.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Armazenar a chave SSH em um cofre de segredos e recuperá-la em tempo de execução usando um token de curta duração.

Um cofre de segredos permite armazenar credenciais de forma centralizada, com controle de acesso, auditoria e rotação sem codificá-las em scripts ou arquivos de texto claro. Senhas estáticas embutidas e permissões de arquivo não eliminam a exposição de um segredo de longa duração, e mudar a linguagem ou a plataforma não resolve a falha de armazenamento de credenciais.

Questão 2: Alternativa B — Criar uma conta de serviço dedicada com permissões apenas para desabilitar contas nas unidades organizacionais alvo.

O script só precisa desabilitar contas específicas, portanto uma conta de serviço dedicada limitada às unidades organizacionais necessárias segue o menor privilégio. Reescrever o script, solicitar credenciais elevadas ou executá-lo em um controlador de domínio não reduz os privilégios excessivos concedidos ao processo de automação.

Questão 3: Alternativa C — Sanitizar ou excluir valores sensíveis antes de gravar dados de depuração.

Variáveis de ambiente frequentemente contêm chaves de API, tokens e senhas. Sanitizar ou excluir valores sensíveis antes de gravar dados de depuração evita vazamento de segredos na origem. Monitoramento de integridade é detectivo, a validação no SIEM não protege o arquivo de depuração, e criptografar com senha compartilhada ainda expõe dados sensíveis a quem tiver a senha.

Questão 4: Alternativa D — Executar uma varredura de análise de composição de software (SCA) nas dependências.

A análise de composição de software examina dependências de terceiros e de código aberto em busca de vulnerabilidades conhecidas, componentes desatualizados e problemas de licença. Análise estática do código de primeira parte pode não encontrar falhas em bibliotecas, política de execução do PowerShell não se aplica a dependências Python, e um firewall de aplicação web não identifica bibliotecas vulneráveis no build.

Questão 5: Alternativa B — Menor privilégio, limitando a função apenas às ações de provisionamento e recursos necessários.

O menor privilégio reduz o raio de impacto se o script de automação ou suas credenciais forem comprometidos. Limitar a função apenas às ações de provisionamento e recursos necessários restringe diretamente o que o script pode fazer. Separação de funções, rotação de funções e férias obrigatórias são controles administrativos que não substituem o escopo técnico de permissões.

Questão 6: Alternativa A — Armazenar scripts em um sistema de controle de versão com revisão por pares obrigatória antes da implantação.

Controle de versão com revisão por pares obrigatória fornece rastreamento de mudanças, responsabilidade e revisão antes de alterações em produção. Desabilitar Bash geralmente é impraticável e pode quebrar operações, restrições de horário não impedem edições não autorizadas, e log detalhado é detectivo, não preventivo.

Questão 7: Alternativa C — Falta de validação de entrada antes de passar dados de alerta para comandos do sistema.

Se dados de alerta forem passados para comandos do sistema sem validação, metacaracteres de shell podem levar à injeção de comandos. Validação de entrada, chamadas seguras de API e comandos parametrizados ajudam a impedir que o script de automação execute comandos controlados pelo atacante. Retenção de logs, criptografia de disco e criptografia Wi-Fi não resolvem essa fraqueza de injeção.

Questão 8: Alternativa A — Verificar assinaturas digitais ou hashes criptográficos dos pacotes antes da instalação.

Verificar assinaturas digitais ou hashes criptográficos garante a integridade e autenticidade do pacote antes da instalação. Janelas de manutenção reduzem a interrupção, o log fornece visibilidade, e usar uma conta de serviço altera o contexto de execução, mas nenhum desses controles prova que o patch não foi adulterado.

Questão 9: Alternativa D — Substituir a chave compartilhada por certificados de curta duração emitidos por um provedor de identidade.

Certificados de curta duração reduzem o impacto do roubo de credenciais, eliminam chaves compartilhadas de longa duração e permitem emissão e expiração centralizadas. Aumentar o tamanho da chave não resolve o compartilhamento, arquivos ZIP protegidos por senha são fracos para segredos de automação, e renomear a conta não traz benefício de segurança.

Questão 10: Alternativa B — Limitar as permissões do script a um grupo definido de endpoints e exigir aprovação para ações de alto impacto.

Limitar permissões a um grupo definido de endpoints segue o menor privilégio, e a aprovação para ações de alto impacto adiciona um controle contra isolamento em massa acidental ou malicioso. Ofuscação não é controle de segurança, executar de uma única estação não limita permissões, e ignorar a política de execução enfraquece a segurança de scripts.